

##CRISCC - Risk Response and Reporting Effectively

###Objectives:

At the end of this episode, I will be able to understand:

1. When it comes to controls, standards and frameworks, mitigation is the most common response to risk
2. Controls are implemented to reduce or maintain risk at acceptable levels
3. Practitioners should verify the correct balance between technical, administrative, and physical controls
4. Might be useful to use a maturity model to see if enterprise controls are effective overall
5. Categories of Controls:
 - Preventative – Inhibit or impede attempts to violate security policy and practices. Encryption, user authentication and vault-construction doors are examples of preventative controls
 - Deterrent – Provide guidance or warnings that may dissuade intentional or unintentional attempts at compromise. Warning banners on login screens, acceptable use policies, security cameras and rewards for the arrest of hackers are examples of deterrent controls
 - Detective – Provide warning of violations or attempted violations of security policy and practices without inhibiting or impeding these actions. Audit trails, IDS systems and checksums are examples.
 - Corrective – Remediate errors, omissions, unauthorized uses and intrusions when detected. Data backups, error correction, and automated failover are examples
 - Compensating – Offsets a deficiency or weakness in the control structure of the enterprise. Placing unsecured systems on isolated network segments with strong perimeter security is an example. Using third party login authentication on systems that don't have it natively.
6. Types of Controls:
 - Administrative. Typically performed by people rather than automated. This would include policy and procedures, training and awareness, configuration and change management.
 - Technical – Done through digital technology. Sometimes logical controls. Include firewalls, network or host based intrusion detection systems, passwords and antivirus software.
 - Physical – Based on restriction of physical access to something. That could be a device or location. Locks, armored doors, security guards and other factors. These require maintenance.
7. Selection of controls requires evaluation and implementation
8. Adopting standards and frameworks facilitates the process of selecting controls
9. ISO 27000 series, PCI DSS, NIST, CSA, etc.
10. These standards and frameworks can also help with governance

Additional resources used during the episode can be obtained using the download link on the overview episode.

External Resources:

During this episode, you can reference the following external resources for supplementary tools and information:

<http://www.isaca.org>